



Domain 1: Security Principles

The CIA Triad:

Confidentiality → Permitting authorized access to information while at the same time protecting it from improper disclosure.

Integrity → Ensuring information's accuracy and completeness, preventing unauthorized modification or deletion.

Availability → Systems and data are accessible at the time users need them.

CIA Triad Deep Dive:

Confidentiality →

- **Personally Identifiable Information (PII)**- Any data about individual that could be used to identify them.
- **Protected Health Information (PHI)**- Information regarding one's Health status, and classified or sensitive information.
- **Sensitivity**- Measure of importance assigned to information by its owner.

Integrity → Something Complete, Consistent and Correct.

- **Data Integrity**- Ensures Information hasn't changed without permission. Data is protected during Storage, Processing and Transfer.
- **System Integrity**- Ensuring expected operational function. (Comparing with Baseline)

Availability → For authorised users, timely and reliable access to data and information services. (In required form & format)

Authentication: Confidentiality

Verifying and providing the user's **identification** is known as Authentication.

- **Something you know:** Password or passphrases. (Knowledge-based)
- **Something you have:** Tokens, smart cards. (Token-based)
- **Something you are:** Biometrics, measurable characteristics. (Characteristics-based)

Methods of Authentication:

- **Single-factor authentication:** Using just one of three factors
- **Multi-factor authentication:** Using two or more factors from the three factors
 - ATM is the best example of Multi-factor Authentication

Non-repudiation:

Provides capability to determine whether given individual performed particular action.

Privacy:

Right of an individual to control how data about them is shared.

- **Privacy:** Focuses on controlling who can access and use information.
- **Security:** Focuses on protecting data from unauthorised access.

Privacy in the working environment:

- **HIPAA:** US Federal law - 1996 (ePHI)
- **GDPR:** European union - 2016 (Even if company is not based on EU)

Protecting the information:

Distinct data can be not considered as PII, but if we have non-distinct data such as individuals Name and other information associated with it then it will be considered as PII.

Risk Identification:

- Identify risk to communicate it clearly.
- Employees at all levels of the organization are responsible for identifying risk.
- Identify risk to protect against it.

Risk Management:

With Risk management technology we can recognize vulnerabilities & threats to calculate likelihood and potential impact of each threat.

- **Vulnerability:** Gap or weakness in protection.
- **Threat:** Something that aims to exploit a Vulnerability to gain unauthorised access.
- **Asset:** Something in need of protection

Risk Assessment:

- Process of identifying, estimating, and prioritizing risks to an organizations operations. (including its mission, functions, image, and reputation)
- Main purpose is to estimate the impact of each solution and prioritize them based on cost, effectiveness, and alignment with organization needs.
- The findings are usually documented in a report or presentation for management to review, approve, and use for decision making.

Risk Treatment:

Making decision about the best actions to take regarding the identified and prioritized risk.

- **Avoidance:** Eliminating by avoiding activities or decisions entirely.
- **Mitigation:** Reducing likelihood or impact of risk through proactive measures such as controls, safeguards, and policies.
- **Acceptance:** Accepting minor risks.
- **Transference:** Shifting the financial or operational burden of risk to another party via insurance policies or contractual agreements.

Risk Priorities:

- Analyze through qualitative (subjective) and / or quantitative (objective) risk analysis.
- Effective way is using risk matrix.

Risk tolerance:

- Willingness and ability to an entity to handle uncertainties or potential losses in its operations, or decision process.
- Executive management and / or Board of Directors determines what is an acceptable level of risk for the organization.
- Security professionals aim to maintain the levels of risk within management limit of risk tolerance.
- It drives decision making

Security Controls:

Measures implemented to safeguard an organization's assets.
(Systems & Data)

- **Physical:** Prevents unauthorised access to physical assets.

- **Administrative:** Policies, procedures and guidelines that govern human behaviour.

- **Technical:** (Logical) Leverages technology to secure assets.

Governance Elements:

Frameworks used to ensure consistency, compliance and accountability within organizations.

1. **Regulations** - Legally binding rules established by governments or regulatory bodies to ensure compliance with laws and protect stakeholders. (Penalties for non-compliance)

Purpose- Ensure legal obligations and protect public interests. (Ex.- GDPR, HIPAA, SOX)

2. **Standards** - Voluntary guidelines developed by organizations and or industry groups to establish best practices for achieving specific goals.

Purpose- Ensure consistency and quality across industries. (Ex.- ISO, NIST, IETF, IEEE)

3. **Policies** - High-level document that define an organization's approach to security, behaviour and operations.

Purpose- Set organization's expectations and enforce consistent decision making.

4. **Procedures** - Step by step instructions on how to implement policies or perform tasks.

Purpose- Operationalize policies through actionable steps.

Standard Organizations and Agencies:

- **ISO (International Organization for Standardization):** Creates international standards for various industries, including ISO/IEC 27001 for information security management systems.
- **NIST (National Institute of Standards and Technology):** U.S. government agency that develops cybersecurity frameworks, guidelines, and best practices like the NIST Cybersecurity Framework.
- **IETF (Internet Engineering Task Force):** Open international community that develops and promotes internet standards, particularly the technical standards that make up TCP/IP.
- **IEEE (Institute of Electrical and Electronics Engineers):** Professional organization that develops global technology standards, including networking protocols like Wi-Fi (802.11) and Ethernet (802.3).
- **IANA (Internet Assigned Numbers Authority):** Global organization that coordinates and manages key internet resources like IP address allocation and DNS root zone management.
- **ANSI (American National Standards Institute):** U.S. organization that accredits other standards organizations and oversees the development of American national standards.
- **PCI SSC (Payment Card Industry Security Standards Council):** Creates and maintains the PCI DSS (Data Security Standard) for organizations that handle credit card information.

Secrecy:

Hiding Something from unauthorised access (Confidentiality).

ISC2 Code of Ethics Preamble:

- The safety and welfare of society and the common good, duty to our principals, and duty to each other, require that we adhere, and be seen to adhere, to the highest ethical standards of behavior.
- Therefore, strict adherence to this Code is a condition of certification.

ISC2 Code of Ethics Canons:

- Protect society, the common good, necessary public trust and confidence, and the infrastructure.
- Act honorably, honestly, justly, responsibly, and legally.
- Provide diligent and competent service to principals.
- Advance and protect the profession.